

# DOCUMENTACIÓN TÉCNICA PROFESIONAL

## Ataque ARP MitM mediante ARP Spoofing

Laboratorio de Seguridad de Redes

|                    |                                                                                                       |
|--------------------|-------------------------------------------------------------------------------------------------------|
| Autor              | Michael David Robles Fermín                                                                           |
| Matrícula          | 2025-0845                                                                                             |
| Repositorio        | <a href="https://github.com/iClexi/ARP-MITM-Attack">https://github.com/iClexi/ARP-MITM-Attack</a>     |
| Video demostrativo | <a href="https://www.youtube.com/watch?v=DnInpZtWHs0">https://www.youtube.com/watch?v=DnInpZtWHs0</a> |
| Red de laboratorio | 20.25.8.0/24                                                                                          |

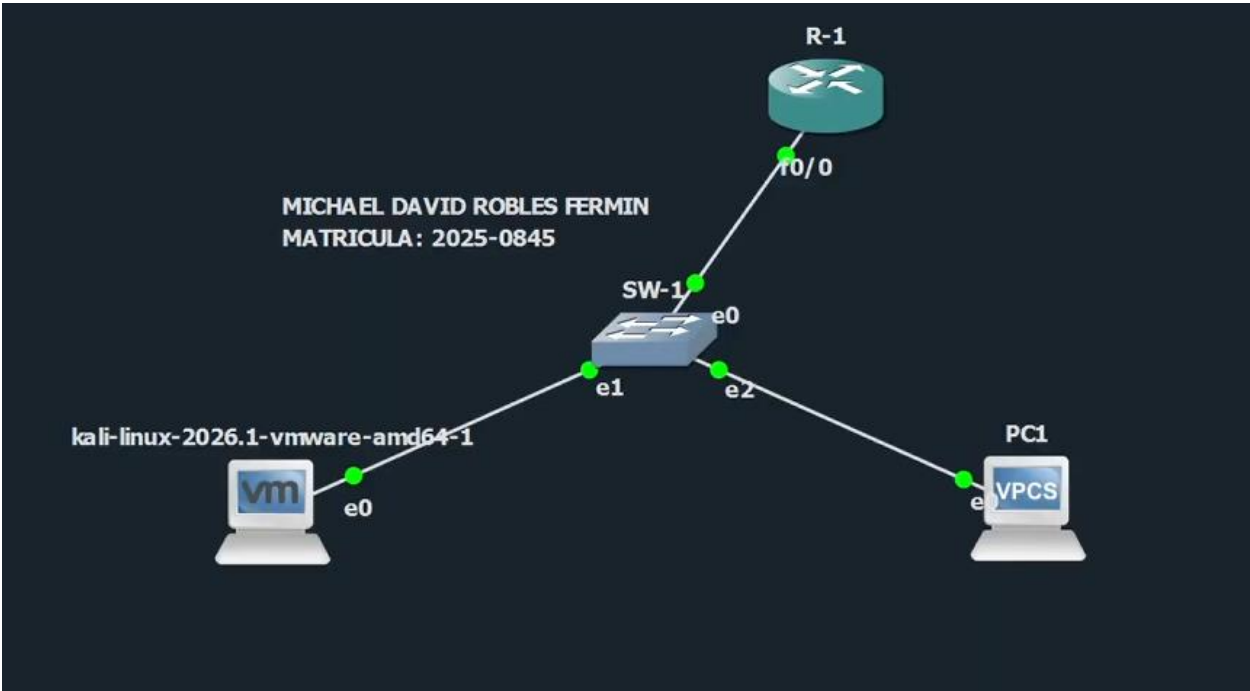


Figura 1. Topología general utilizada para el laboratorio ARP MitM.

# Índice

|                                                  |    |
|--------------------------------------------------|----|
| Índice.....                                      | 2  |
| 1. Introducción.....                             | 3  |
| 2. Objetivos .....                               | 3  |
| 2.1 Objetivo del laboratorio .....               | 3  |
| 2.2 Objetivo del script .....                    | 3  |
| 3. Alcance y uso responsable .....               | 3  |
| 4. Documentación de la red .....                 | 4  |
| 5. Requisitos para utilizar la herramienta ..... | 5  |
| 6. Parámetros usados .....                       | 5  |
| 7. Estado inicial antes del ataque.....          | 6  |
| 8. Ejecución del ataque .....                    | 7  |
| 9. Funcionamiento técnico del script .....       | 8  |
| 10. Evidencia del impacto .....                  | 8  |
| 11. Demostración de daño con iptables .....      | 9  |
| 12. Contramedida documentada .....               | 10 |
| 13. Verificación posterior a la mitigación ..... | 11 |
| 14. Video demostrativo.....                      | 11 |
| 15. Conclusión .....                             | 11 |
| 16. Referencias .....                            | 11 |

# 1. Introducción

Este documento presenta la documentación técnica profesional del laboratorio de ataque Man-in-the-Middle mediante ARP Spoofing. La práctica fue realizada en un entorno controlado de GNS3 con una máquina Kali Linux como atacante, un router Cisco como gateway, un switch de capa 2 y una víctima PC1/VPCS.

El ataque ARP MitM aprovecha que el protocolo ARP no valida de forma nativa la identidad de los dispositivos que responden en la red local. Por esta razón, un atacante puede enviar respuestas ARP falsas y lograr que la víctima y el gateway asocien direcciones IP legítimas con la dirección MAC del atacante.

## 2. Objetivos

### 2.1 Objetivo del laboratorio

Demostrar cómo una máquina atacante conectada a la misma red local puede colocarse entre una víctima y su gateway mediante envenenamiento ARP, permitiendo afectar o controlar el tráfico que transita entre ambos dispositivos.

### 2.2 Objetivo del script

Automatizar el envío de respuestas ARP falsificadas hacia la víctima y hacia el gateway, activar el reenvío de paquetes en Kali Linux y permitir demostrar el impacto del ataque mediante bloqueo selectivo de tráfico ICMP con iptables.

## 3. Alcance y uso responsable

Este laboratorio fue desarrollado exclusivamente con fines educativos, académicos y de práctica controlada. Las técnicas descritas deben utilizarse únicamente en entornos propios o autorizados, como GNS3, EVE-NG, PNETLab o laboratorios internos de pruebas. No se autoriza su uso en redes públicas, empresariales o de terceros sin permiso explícito.

## 4. Documentación de la red

La red de laboratorio utiliza el segmento 20.25.8.0/24. El router R-1 funciona como gateway, Kali ejecuta el ataque y PC1 representa la víctima.

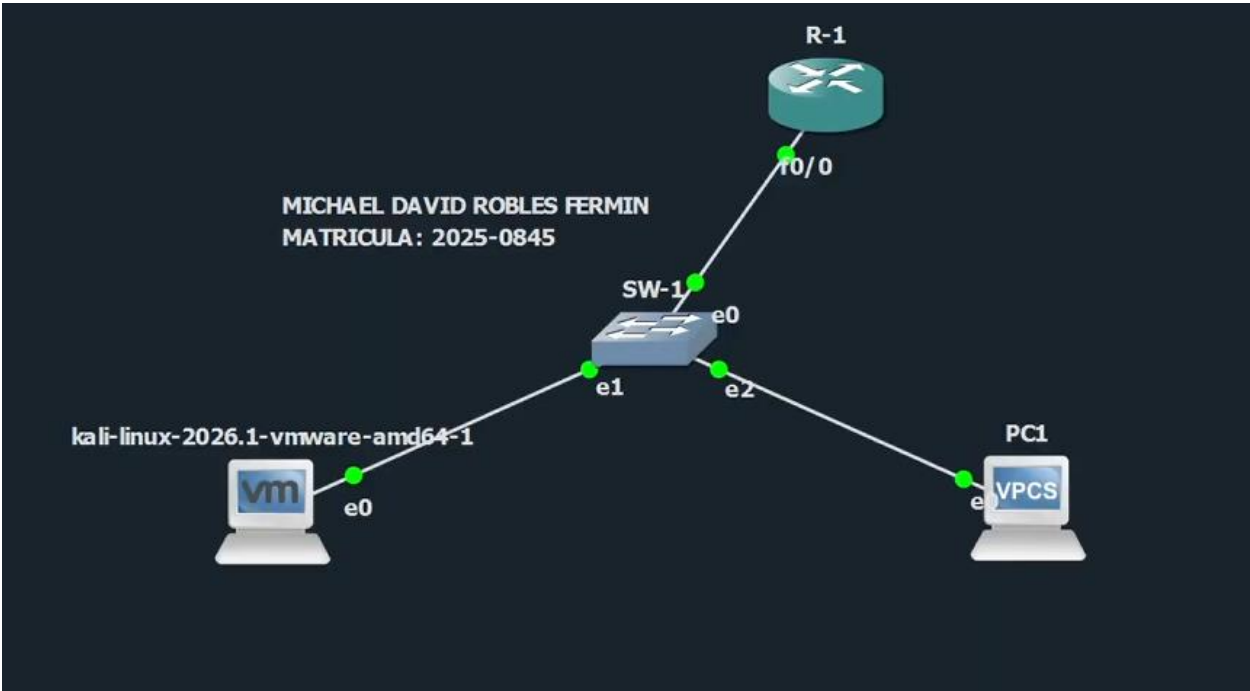


Figura 2. Topología con R-1, SW-1, Kali y PC1.

| Dispositivo | Rol           | Interfaz        | IP            | MAC relevante  |
|-------------|---------------|-----------------|---------------|----------------|
| R-1         | Gateway       | FastEthernet0/0 | 20.25.8.45/24 | cc01.0c14.0000 |
| SW-1        | Switch capa 2 | e0/e1/e2        | N/A           | N/A            |
| Kali        | Atacante      | eth0            | 20.25.8.46/24 | 000c.2958.5008 |
| PC1         | Víctima       | e0              | 20.25.8.47/24 | 0050.7966.6800 |

## 5. Requisitos para utilizar la herramienta

- Kali Linux con Python 3.
- Permisos de superusuario para enviar paquetes ARP y modificar iptables.
- Conectividad directa de capa 2 con la víctima y el gateway.
- Router Cisco o dispositivo equivalente funcionando como gateway.
- Switch IOSvL2 o switch de capa 2 dentro del laboratorio.
- Repositorio iClexi/ARP-MITM-Attack clonado en Kali.

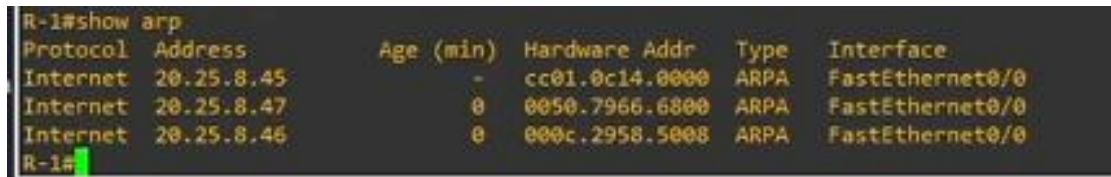
## 6. Parámetros usados

| Parámetro  | Valor usado | Descripción                                    |
|------------|-------------|------------------------------------------------|
| Interfaz   | eth0        | Interfaz de Kali conectada al switch.          |
| IP víctima | 20.25.8.47  | Dirección IP de PC1.                           |
| IP gateway | 20.25.8.45  | Dirección IP de R-1.                           |
| Intervalo  | 0.05        | Tiempo entre rondas de envenenamiento ARP.     |
| Burst      | 20          | Cantidad de paquetes ARP enviados por ronda.   |
| Duración   | 0           | Ejecución indefinida hasta detener con Ctrl+C. |

## 7. Estado inicial antes del ataque

Antes de iniciar el ataque, las tablas ARP muestran asociaciones legítimas. R-1 reconoce a PC1 con su MAC real y PC1 reconoce al gateway con la MAC real del router.

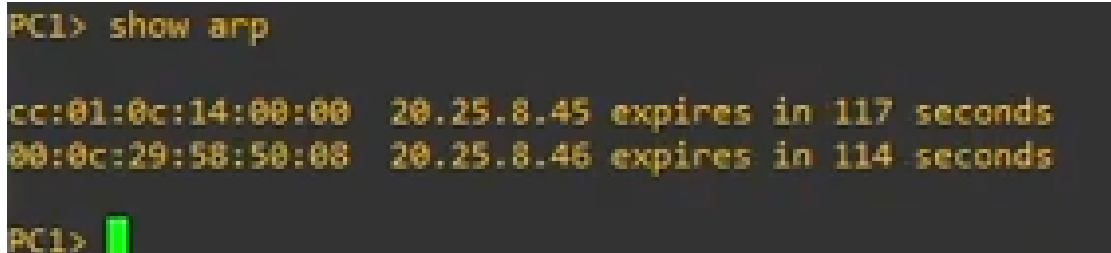
R-1# show arp



| Protocol | Address    | Age (min) | Hardware Addr  | Type | Interface       |
|----------|------------|-----------|----------------|------|-----------------|
| Internet | 20.25.8.45 | -         | cc01.0c14.0000 | ARPA | FastEthernet0/0 |
| Internet | 20.25.8.47 | 0         | 0050.7966.6800 | ARPA | FastEthernet0/0 |
| Internet | 20.25.8.46 | 0         | 000c.2958.5008 | ARPA | FastEthernet0/0 |

Figura 3. Tabla ARP de R-1 antes del ataque.

PC1> show arp



| Hardware Addr     | Address    | Expires                |
|-------------------|------------|------------------------|
| cc:01:0c:14:00:00 | 20.25.8.45 | expires in 117 seconds |
| 00:0c:29:58:50:08 | 20.25.8.46 | expires in 114 seconds |

Figura 4. Tabla ARP de PC1 antes del ataque.

## 8. Ejecución del ataque

El ataque se ejecuta desde Kali Linux usando el script arp-mitm.py. Durante su inicio, el script muestra la configuración utilizada, resuelve las MAC de la víctima y del gateway, activa IP forwarding y comienza el envenenamiento ARP.

```
sudo python3 arp-mitm.py
```



```
(kali@kali)-[~]
$ sudo python3 arp-mitm.py

Interfaces disponibles:

1. eth0          UP          20.25.8.46/24 fe80::7dd6:79b3:1d4:e0da/64
2. eth1          DOWN

Interfaz que usará el ataque [Enter = eth1]: 1
IP de la víctima [Enter = 20.25.8.47]:
IP del gateway [Enter = 20.25.8.45]:

Configuración ARP MitM:
iface=eth0
iface_info=eth0          UP          20.25.8.46/24 fe80::7dd6:79b3:1d4:e0da/64
attacker_mac=00:0c:29:58:50:08
target_ip=20.25.8.47
gateway_ip=20.25.8.45
interval=0.05
burst=20
duration=0

Presiona Enter para iniciar o escribe n para cancelar:

Resolviendo MAC de la víctima y del gateway
target_mac=00:0c:29:b0:97:06
gateway_mac=cc:01:0c:14:00:00
IP forwarding activado

Ataque ARP MitM iniciado. Usa Ctrl+C para detener
```

Figura 5. Ejecución del script ARP MitM en Kali Linux.

## 9. Funcionamiento técnico del script

El script envía respuestas ARP falsas en dos direcciones. Primero, le indica a PC1 que la IP del gateway 20.25.8.45 corresponde a la MAC de Kali. Segundo, le indica a R-1 que la IP de PC1 20.25.8.47 corresponde también a la MAC de Kali. De esta forma, ambos extremos envían su tráfico hacia el atacante.

Al activar IP forwarding, Kali puede reenviar tráfico entre víctima y gateway, manteniendo la comunicación mientras conserva una posición de intermediario. En este laboratorio se demuestra el control del tráfico usando iptables para bloquear ICMP desde PC1 hacia R-1.

## 10. Evidencia del impacto

Durante el ataque, la tabla ARP de PC1 muestra que la IP del gateway quedó asociada a la MAC del atacante. Esto confirma que la víctima fue envenenada.

```
PC1> show arp
00:0c:29:58:50:08 20.25.8.45 expires in 120 seconds
00:0c:29:58:50:08 20.25.8.47 expires in 120 seconds
00:0c:29:58:50:08 20.25.8.46 expires in 118 seconds
PC1>
```

Figura 6. Tabla ARP de PC1 envenenada.

En R-1 también se observa que la IP de PC1 aparece asociada a la MAC de Kali. Esta evidencia confirma que el envenenamiento ocurrió en ambos sentidos.

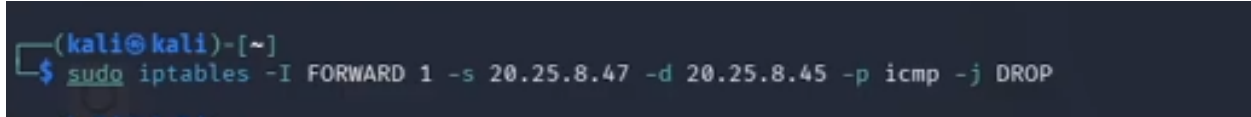
```
R-1#show arp
Protocol Address      Age (min) Hardware Addr  Type   Interface
Internet 20.25.8.45          -    cc01.0c14.0000  ARPA   FastEthernet0/0
Internet 20.25.8.47           0    000c.2958.5008  ARPA   FastEthernet0/0
Internet 20.25.8.46           0    000c.2958.5008  ARPA   FastEthernet0/0
R-1#
```

Figura 7. Tabla ARP de R-1 envenenada.

## 11. Demostración de daño con iptables

Para demostrar que el tráfico pasa por Kali, se aplica una regla iptables que bloquea ICMP desde PC1 hacia R-1.

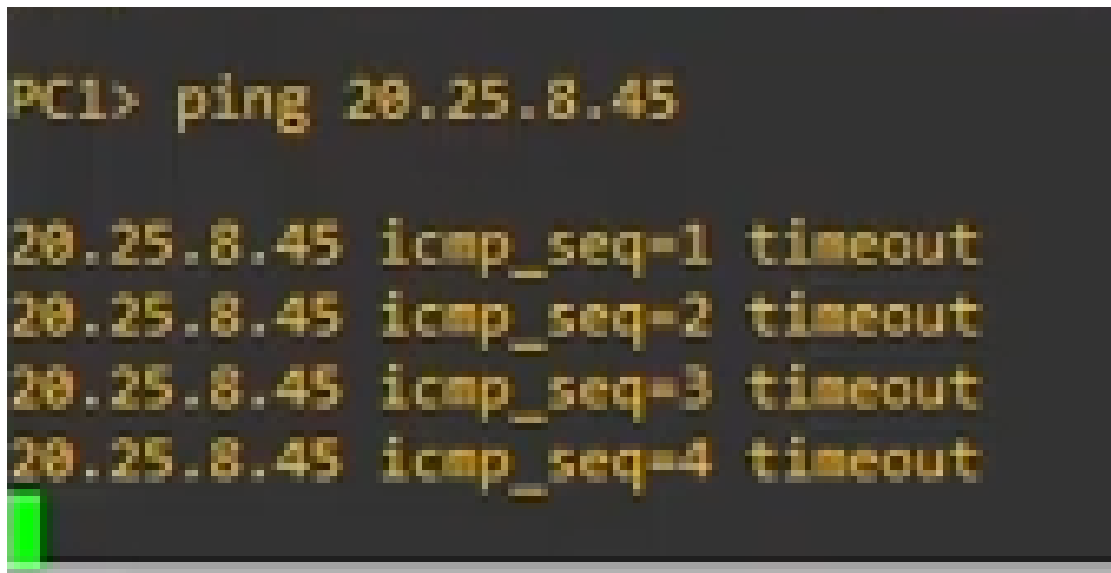
```
sudo iptables -I FORWARD 1 -s 20.25.8.47 -d 20.25.8.45 -p icmp -j DROP
```



```
(kali@kali)-[~]  
$ sudo iptables -I FORWARD 1 -s 20.25.8.47 -d 20.25.8.45 -p icmp -j DROP
```

*Figura 8. Regla iptables aplicada en Kali.*

Luego se realiza ping desde PC1 hacia el gateway. El resultado muestra timeouts, evidenciando que el tráfico fue afectado por el atacante.



```
PC1> ping 20.25.8.45  
  
20.25.8.45 icmp_seq=1 timeout  
20.25.8.45 icmp_seq=2 timeout  
20.25.8.45 icmp_seq=3 timeout  
20.25.8.45 icmp_seq=4 timeout
```

*Figura 9. Ping bloqueado desde PC1 hacia R-1.*

## 12. Contramedida documentada

La contramedida aplicada es Dynamic ARP Inspection con ARP ACL estática. Esta técnica permite al switch validar manualmente las combinaciones IP-MAC legítimas y bloquear respuestas ARP falsificadas que no coincidan con la lista autorizada.

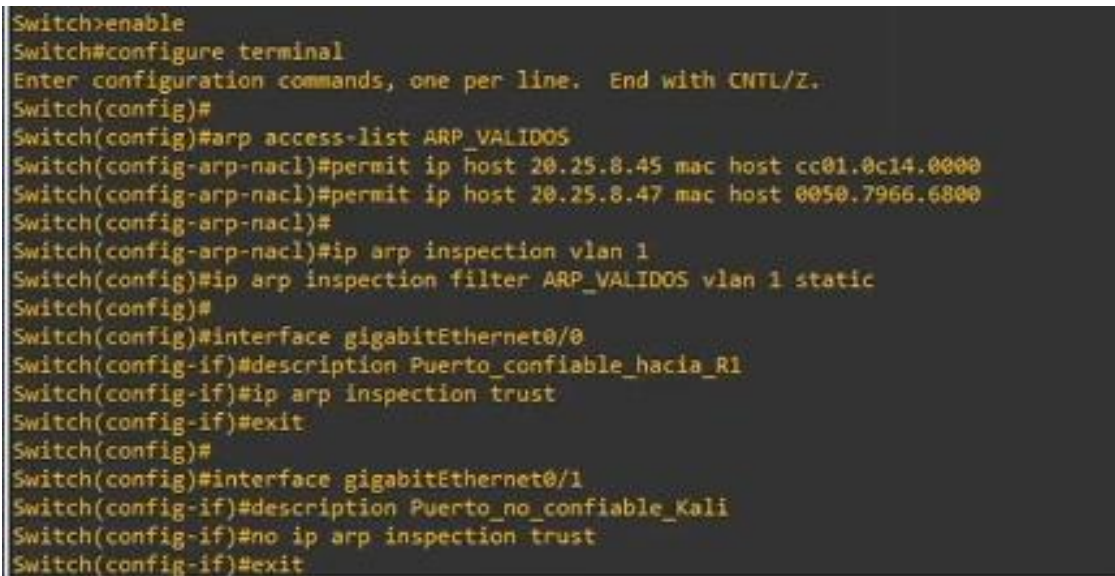
En este laboratorio se autorizan las asociaciones del gateway R-1 y de PC1. El puerto hacia R-1 se marca como confiable y el puerto hacia Kali se mantiene como no confiable.

```
arp access-list ARP_VALIDOS
permit ip host 20.25.8.45 mac host cc01.0c14.0000
permit ip host 20.25.8.47 mac host 0050.7966.6800

ip arp inspection vlan 1
ip arp inspection filter ARP_VALIDOS vlan 1 static

interface gigabitEthernet0/0
ip arp inspection trust

interface gigabitEthernet0/1
no ip arp inspection trust
```



```
Switch>enable
Switch#configure terminal
Enter configuration commands, one per line. End with CNTL/Z.
Switch(config)#
Switch(config)#arp access-list ARP_VALIDOS
Switch(config-arp-nacl)#permit ip host 20.25.8.45 mac host cc01.0c14.0000
Switch(config-arp-nacl)#permit ip host 20.25.8.47 mac host 0050.7966.6800
Switch(config-arp-nacl)#
Switch(config-arp-nacl)#ip arp inspection vlan 1
Switch(config)#ip arp inspection filter ARP_VALIDOS vlan 1 static
Switch(config)#
Switch(config)#interface gigabitEthernet0/0
Switch(config-if)#description Puerto_confiable_hacia_R1
Switch(config-if)#ip arp inspection trust
Switch(config-if)#exit
Switch(config)#
Switch(config)#interface gigabitEthernet0/1
Switch(config-if)#description Puerto_no_confiable_Kali
Switch(config-if)#no ip arp inspection trust
Switch(config-if)#exit
```

Figura 10. Configuración de Dynamic ARP Inspection y ARP ACL estática.

### 13. Verificación posterior a la mitigación

Después de aplicar la mitigación, se debe repetir el ataque y verificar que PC1 conserve la MAC real del gateway y que R-1 conserve la MAC real de PC1. También se recomienda revisar las estadísticas de inspección ARP en el switch.

```
show ip arp inspection
show ip arp inspection statistics
show arp access-list
show arp
```

### 14. Video demostrativo

La demostración práctica del ataque y su mitigación está disponible en YouTube:

<https://www.youtube.com/watch?v=DnInpZtWHs0>

### 15. Conclusión

El laboratorio demuestra que ARP puede ser abusado para ejecutar ataques Man-in-the-Middle dentro de una red local. El atacante logra que la víctima y el gateway asocien direcciones IP legítimas con su propia MAC, permitiéndole quedar en medio del tráfico.

La mitigación con Dynamic ARP Inspection y ARP ACL estática protege la red al permitir únicamente asociaciones IP-MAC autorizadas. Esta defensa es especialmente útil en laboratorios o redes pequeñas donde se conocen las direcciones críticas que deben protegerse.

### 16. Referencias

Repositorio: <https://github.com/iClexi/ARP-MITM-Attack>

Video demostrativo: <https://www.youtube.com/watch?v=DnInpZtWHs0>

Práctica realizada en laboratorio controlado de Seguridad de Redes.